

NAME: THULASI.S

DATE: 14.02.26

ROLL NO:241901118

EXPERIMENT 5

SUDO BUFFER OVERFLOW

AIM:

To understand and exploit a buffer overflow vulnerability in a program running with sudo privileges, to gain elevated (root) access.

ALGORITHM:

1. Log in to TryHackMe.
2. Check sudo permissions using: `sudo-l`.
3. Identify the vulnerable program.
4. Give a large input to test the buffer overflow.
5. Find overflow offset using tools/debugging.
6. Create an exploit payload (padding + return address)
7. Run the program with sudo using the payload.
8. Verify root access using: `whoami`.

Task 1 Deploy!

To deploy this virtual machine you must be connected to the TryHackMe network using your OpenVPN configuration file. If you don't know how to do this, take a quick look at the [OpenVPN room](#) first.

[▶ Start Machine](#)

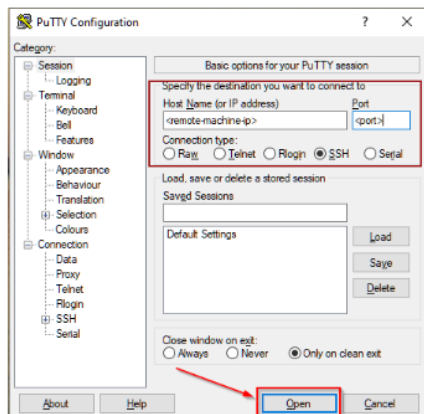
Once you're connected click the green "Deploy" button to start an instance of the machine, then we can get started!

(Please note that VMs can take a few minutes to boot up fully)

You will be using SSH to log into the machine. On Linux this is done from the terminal, with a command that looks like this:

```
ssh -p <port-number> <username>@<remote-machine-ip>
```

On Windows you would usually use a piece of software such as [PuTTY](#). You would then login like this:



Whichever method you're using, you will then be asked for a password, which, once entered, will let you execute commands remotely on the machine. Credentials will be provided later in the room.

Answer the questions below

Deployed!

No answer needed

Correct Answer

Task 2 Buffer Overflow

CVE-2019-18634 is, at the time of writing, the latest offering from Joe Vennix - the same guy who brought us the security bypass vulnerability that we used in the Security Bypass room. This one is slightly more technical, using a Buffer Overflow attack to get root permissions. It has been patched, but affects versions of sudo earlier than 1.8.26.

Let's break this down a little bit.

In the [Security Bypass room](#) I mentioned briefly that you can add things to the `/etc/sudoers` file in order to give lower-privileged users extra permissions. For this exploit we're more interested in one of the other options available: specifically an option called `pwfeedback`. This option is purely aesthetic, and is usually turned off by default (with the exception of ElementaryOS and Linux Mint - although they will likely now also stop using it). If you have used Linux before then you might have noticed that passwords typed into the terminal usually don't show any output at all: `pwfeedback` makes it so that whenever you type a character, an asterisk is displayed on the screen. Inside the `/etc/sudoers` file it is specified like this:

Answer the questions below

Use the pre-compiled exploit in the VM to get a root shell.

No answer needed

Correct Answer

What's the flag in `/root/root.txt`?

THM{buff3r_0v3rfl0w_ru13s}

Correct Answer

RESULT:

The buffer overflow vulnerability in the sudo-executable program was successfully exploited, allowing unauthorised privilege escalation and access to the root shell.